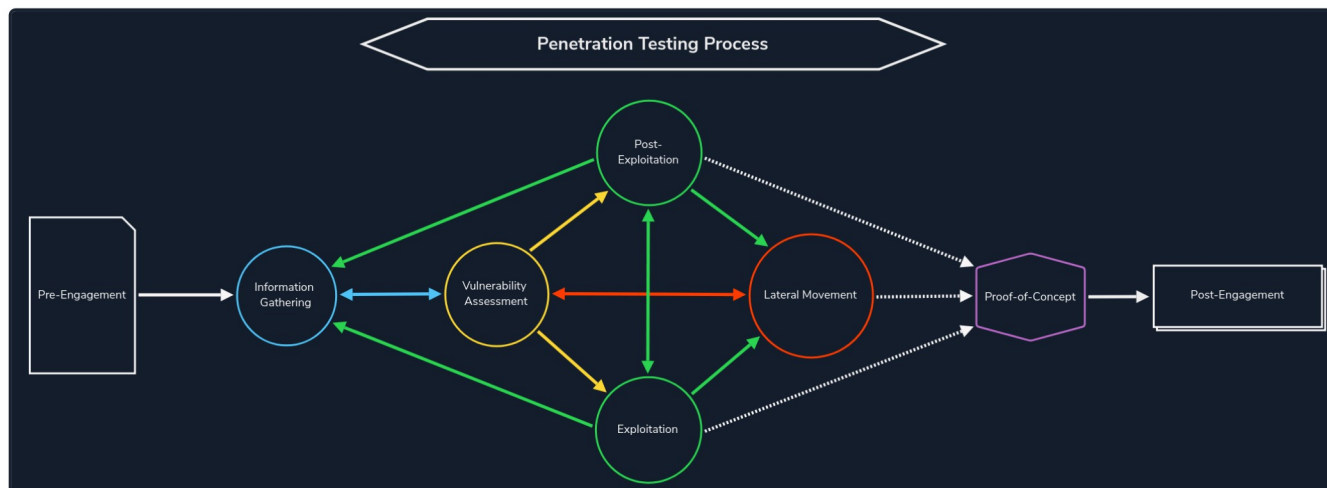


Information Gathering

The **information gathering** phase is the first step in every penetration test where we need to simulate external attackers without internal information from the target organization. This phase is crucial as poor and rushed information gathering could result in missing flaws that otherwise thorough enumeration would have uncovered.



This phase helps us understand the attack surface, technologies used, and, in some cases, discover development environments or even forgotten and unmaintained infrastructure that can lead us to internal network access as they are usually less protected and monitored. Information gathering is typically an iterative process. As we discover assets (say, a subdomain or virtual host), we will need to fingerprint the technologies in use, look for hidden pages/directories, etc., which may lead us to discover another subdomain and start the process over again.

For example, we can think of it as stumbling across new subdomains during one of our penetration tests based on the SSL certificate. However, if we take a closer look at these subdomains, we will often see different technologies in use than the main company website. Subdomains and vhosts are used to present other information and perform other tasks that have been separated from the homepage. Therefore, it is essential to find out which technologies are used, what purpose they serve, and how they work. During this process, our objective is to identify as much information as we can from the following areas:

Area	Description
Domains and Subdomains	Often, we are given a single domain or perhaps a list of domains and subdomains that belong to an organization. Many organizations do not have an accurate asset inventory and may have forgotten both domains and subdomains exposed externally. This is an essential part of the reconnaissance phase. We may come across various subdomains that map back to in-scope IP addresses, increasing the overall attack surface of our engagement (or bug bounty program). Hidden and forgotten subdomains may have old/vulnerable versions of applications or dev versions with additional functionality (a Python debugging console, for example). Bug bounty programs will often set the scope as something such as <code>*.inlanefreight.com</code> , meaning that all subdomains of <code>inlanefreight.com</code> , in this example, are in-scope (i.e., <code>acme.inlanefreight.com</code> , <code>admin.inlanefreight.com</code> , and so forth and so on). We may also discover subdomains of subdomains. For example, let's assume we discover something along the lines of <code>admin.inlanefreight.com</code> . We could then run further subdomain enumeration against this subdomain and perhaps find <code>dev.admin.inlanefreight.com</code> as a very enticing target. There are many ways to find subdomains (both passively and actively) which we will cover later in this module.
IP ranges	Unless we are constrained to a very specific scope, we want to find out as much about our target as possible. Finding additional IP ranges owned by our target may lead to discovering other domains and subdomains and open up our possible attack surface even wider.
Infrastructure	We want to learn as much about our target as possible. We need to know what technology stacks our target is using. Are their applications all ASP.NET? Do they use Django, PHP, Flask, etc.? What type(s) of APIs/web services are in use? Are they using Content Management Systems (CMS) such as WordPress, Joomla, Drupal, or DotNetNuke, which have their own types of vulnerabilities and misconfigurations that we may encounter? We also care about the web servers in use, such as IIS, Nginx, Apache, and the version numbers. If our target is running outdated frameworks or web servers, we want to dig deeper into the associated web applications. We are also interested in the types of back-end databases in use (MSSQL, MySQL, PostgreSQL, SQLite, Oracle, etc.) as this will give us an indication of the types of attacks we may be able to perform.

Virtual Hosts Lastly, we want to enumerate virtual hosts (vhosts), which are similar to subdomains but indicate that an organization is hosting multiple applications on the same web server. We will cover vhost enumeration later in the module as well.

We can break the information gathering process into two main categories:

Category	Description
Passive information gathering	We do not interact directly with the target at this stage. Instead, we collect publicly available information using search engines, whois, certificate information, etc. The goal is to obtain as much information as possible to use as inputs to the active information gathering phase.
Active information gathering	We directly interact with the target at this stage. Before performing active information gathering, we need to ensure we have the required authorization to test. Otherwise, we will likely be engaging in illegal activities. Some of the techniques used in the active information gathering stage include port scanning, DNS enumeration, directory brute-forcing, virtual host enumeration, and web application crawling/spidering.

It is crucial to keep the information that we collect well-organized as we will need various pieces of data as inputs for later phasing of the testing process. Depending on the type of assessment we are performing, we may need to include some of this enumeration data in our final report deliverable (such as an External Penetration Test). When writing up a bug bounty report, we will only need to include details relevant specifically to the bug we are reporting (i.e., a hidden subdomain that we discovered led to the disclosure of another subdomain that we leveraged to obtain remote code execution (RCE) against our target).

It is worth signing up for an account at [Hackerone](#), perusing the program list, and choosing a few targets to reproduce all of the examples in this module. Practice makes perfect. Continuously practicing these techniques will help us hone our craft and make many of these information gathering steps second nature. As we become more comfortable with the tools and techniques shown throughout this module, we should develop our own, repeatable methodology. We may find that we like specific tools and command-line techniques for some phases of information gathering and discover different tools that we prefer for other phases. We may want to write out our own scripts to automate some of these phases as well.

Moving On

Let's move on and discuss passive information gathering. For the module section examples and exercises, we will focus on Facebook, which has its own [bug bounty program](#), [PayPal](#), [Tesla](#), and internal lab hosts. While performing the information gathering examples, we must be sure not to stray from the program scope, which lists in-scope and out-of-scope websites and applications and out-of-scope attacks such as physical security attacks, social engineering, the use of automated vulnerability scanners, man-in-the-middle attacks, etc.

[Next →](#)[✔ Mark Complete & Next](#)[📄 Cheat Sheet](#)

Table of Contents

[Information Gathering](#)

Passive Information Gathering

[📄 WHOIS](#)[📄 DNS](#)[Passive Subdomain Enumeration](#)[Passive Infrastructure Identification](#)

Active Information Gathering

-  Active Infrastructure Identification
-  Active Subdomain Enumeration
-  Virtual Hosts

Crawling

Putting it all Together

-  Information Gathering - Web - Skills Assessment

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left